

NAME: AYOBAMI OSHODI

REG NO: C11/26/CGRCE/17555

DATE: 18/09/2026

WEEK 2 PRACTICAL LABORATORY

Developing Security Policies
and Procedures

NexusTech Solutions — Policy Overhaul Simulation

EVIDENCE BUNDLE 1 - ESTABLISH THE SECURITY POLICY HIERARCHY

Policy Hierarchy Definition

Document Type	Purpose	Authority	Mandatory / Recommended	Level of Detail
Policy	Defines management's intentions, objectives, rules and expectations for information security.	Highest organisational authority; approved by senior management.	Mandatory	High-level; explains what must or must not be done and why.
Standard	Establishes specific, measurable and mandatory requirements that support a policy.	Approved by the appropriate management or governance authority.	Mandatory	More specific than a policy; defines required configurations, thresholds or controls.
Guideline	Provides advice and recommended practices to help employees achieve security objectives.	Usually issued or approved by the relevant security/technical function.	Recommended	Practical guidance; explains preferred approaches without normally creating mandatory requirements.
Procedure	Provides the sequential steps required to perform a specific activity consistently.	Approved by the responsible process owner/management authority.	Mandatory when applicable	Detailed and action-oriented; explains how to perform a task.

This hierarchy separates strategic policy requirements from measurable standards, recommended guidance and step-by-step procedures. It addresses NexusTech's existing documentation problem in which high-level intent, technical instructions and vague recommendations have been mixed together.

Categorisation of the Eight Statements

No.	Statement	Classification	Justification
1	All NexusTech employees must use MFA when accessing the corporate network remotely.	Policy	Establishes a mandatory security requirement without explaining the technical implementation steps.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	Provides sequential instructions for completing a specific task.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	Uses recommended language and provides security advice rather than an absolute mandatory requirement.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	Expresses a high-level organisational security commitment and objective.
5	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	Defines a precise, measurable and mandatory technical requirement.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	Provides recommended behaviour using 'should' rather than an absolute mandatory control.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	Gives users a specific operational action to take when a security event occurs.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	Defines precise, measurable and mandatory password requirements.

EVIDENCE BUNDLE 2 - DRAFT AN EFFECTIVE ACCEPTABLE USER POLICY

NexusTech Solutions — Acceptable Use Policy

Document Control Field	Value
Document Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027
Classification	Internal

Purpose

The purpose of this Acceptable Use Policy (AUP) is to establish clear requirements for the appropriate and responsible use of NexusTech Solutions' information systems, company-provided devices, networks, applications and information resources. The policy is intended to reduce security, malware, privacy, operational and compliance risks while ensuring that company resources are used effectively for legitimate business activities.

Scope

This policy applies to all NexusTech employees, contractors, consultants, temporary workers and other authorised users; company-owned or company-managed devices; corporate networks, systems, applications, cloud services and communication platforms; and information created, accessed, processed, stored or transmitted using NexusTech resources.

Acceptable Use

- Use NexusTech systems and devices primarily for legitimate business purposes.
- Protect company credentials, authentication information and access mechanisms from unauthorised use.
- Use only accounts and systems for which the user has been authorised.
- Handle company and client information in accordance with applicable security and confidentiality requirements.
- Report suspected security incidents, unauthorised access, malware or accidental disclosure promptly through the approved reporting channel.
- Follow applicable NexusTech security policies, standards and procedures.
- Take reasonable precautions when accessing company systems from remote locations.
- Keep company devices physically secure and not knowingly make them available to unauthorised persons.
- Use licensed and authorised software and services for business activities.

Prohibited Activities

- Access, modify, copy, delete or disclose information without appropriate authorisation.
- Share passwords, authentication codes or other credentials with another person.
- Circumvent or attempt to disable security controls.
- Install unauthorised software or applications on company-managed devices.
- Download files or software from sources known or reasonably suspected to be malicious.
- Use NexusTech systems to conduct illegal activities.

- Use company systems to harass, threaten, discriminate against or otherwise unlawfully harm another person.
- Store or transmit confidential company or client information through unauthorised personal cloud-storage accounts.
- Connect unauthorised devices to protected corporate systems or networks where doing so creates a security risk.
- Deliberately introduce malware or other malicious code into NexusTech systems.
- Use company resources in ways that create an unacceptable security, legal, regulatory or reputational risk.

Reasonable Personal Use

Limited personal use of NexusTech systems may be permitted where it:

- Is occasional and reasonable.
- Does not interfere with work responsibilities.
- Does not consume excessive organisational resources.
- Does not violate this policy or applicable law.
- Does not create security, privacy, legal or reputational risks.
- Does not involve unauthorised software, services or storage.

Use of Company Devices

- Keep devices protected against loss, theft and unauthorised access.
- Use approved security controls.
- Do not deliberately disable security protections.
- Promptly report lost, stolen or compromised devices.
- Return company equipment when requested or when employment or engagement ends.

Internet, Email and Communication Systems

NexusTech communication systems must be used responsibly and primarily for authorised business activities. Users must exercise caution when opening links, attachments or messages from unknown or suspicious sources and must report suspected phishing or malicious activity through the approved reporting channel.

Data Protection and Confidentiality

Users must protect NexusTech and client information from unauthorised access, disclosure, modification or loss. Sensitive information must not be transferred to personal email accounts, personal cloud storage or other unauthorised services. Users must only access information required for their legitimate duties.

Monitoring and Security Controls

NexusTech may implement appropriate monitoring and security controls to protect its systems, information and users, subject to applicable law and organisational requirements. Users must not attempt to bypass, interfere with or disable authorised monitoring and security controls.

Roles and Responsibilities

Role	Responsibilities
Employees and Other Users	Understand and comply with the policy; protect credentials and assigned devices; use resources appropriately; report suspected incidents.
IT and Information Security	Support implementation; maintain appropriate technical controls; provide guidance and awareness; investigate security concerns as appropriate.
Managers	Ensure team members understand requirements; support appropriate access and resource use; escalate repeated or serious violations.
Human Resources	Support employee communication and disciplinary processes where policy violations involve employment matters.

Compliance and Enforcement

Compliance with this policy is mandatory. Violations may result in corrective action, restriction or removal of system access, disciplinary action and/or other measures permitted by organisational policy and applicable law. Serious incidents may be escalated to senior management, Information Security, HR, legal counsel or relevant authorities where appropriate.

Exceptions

Exceptions must be business-justified, documented, risk-assessed, approved by the appropriate authority before implementation where practicable, and time-limited. Emergency situations may be handled under the organisation's emergency or incident-management process, with retrospective documentation and approval where necessary.

Policy Compliance and Acknowledgement

All covered users must acknowledge that they have received, understood and agree to comply with this policy. Failure to acknowledge the policy may result in escalation to the user's manager and HR, subject to organisational procedures.

Approval and Review

Policy Owner: Information Security Manager | Approval Authority: Marcus Vance, CEO | Version: 1.0 | Effective Date: 18 September 2026 | Next Scheduled Review: 18 September 2027. The policy may be reviewed earlier where there are significant changes to business operations, technology, regulatory requirements, security risks or incidents.

EVIDENCE BUNDLE 3 - User Access Request Procedure

Document Control Field	Value
Document Title	User Access Request Procedure
Version	1.0
Process Owner	Information Security Manager
Responsible Team	IT Helpdesk
Effective Date	18 September 2026
Review Date	18 September 2027
Classification	Internal

Purpose

This procedure establishes a consistent process for requesting, approving, provisioning, modifying and recording user access to NexusTech systems. The objective is to ensure that access is authorised, appropriate to the user's role and consistent with the principle of least privilege.

Scope

This procedure applies to new user access, additional system access, changes to existing permissions, privileged access, temporary access, emergency access, and removal or modification of access following role changes.

Prerequisites

- Approved access-request ticketing/workflow system.
- Relevant user identity information.
- Manager approval.
- Data-owner or system-owner approval where required.
- Applicable role/access requirements.
- Information necessary to verify the requested level of access.

Informal email, verbal requests or chat messages must not be treated as sufficient authorisation on their own.

Sequential Procedure

Receive the Request

- Confirm the request was submitted through the approved ticketing/workflow system.
- Confirm the request identifies the user, system/resource, requested access and business justification.
- Record the ticket reference.

Verify the User

- Confirm identity and employment/engagement status using approved organisational records.
- Confirm the access relates to the user's current role or documented business requirement.

Verify Approval

- Confirm manager approval.
- Obtain data-owner/system-owner approval where required.
- Do not proceed if required approval is missing.

Assess Least Privilege

- Determine the minimum access required.
- Select the appropriate role-based permission set.
- Check for excessive, conflicting or unnecessary privileges.
- Escalate unusual or privileged requests for appropriate review.

Provision Access

- Create or modify the account using the approved process.
- Assign only approved permissions.

- Apply applicable authentication and security requirements.
- Do not grant additional privileges for convenience.

Verify Access

- Confirm the account and permissions match the approved request.
- Perform basic access verification where appropriate.
- Correct discrepancies before closure.

Notify the User and Manager

- Notify the user through an approved channel.
- Provide only information necessary to access the system securely.
- Notify the manager where required.

Capture Evidence

- Record request details, approvals, identity verification, access/role, provisioning date/time, responsible technician, exceptions and verification results.

Close the Ticket

- Confirm all required actions and approvals are documented.
- Confirm evidence is captured.
- Record final status and close the ticket.

Emergency or Exceptional Requests

1. Confirm the emergency justification.
2. Obtain approval from the designated emergency approver where practicable.
3. Grant the minimum necessary access.
4. Make emergency access time-limited where technically possible.
5. Document the emergency action.
6. Obtain retrospective review and approval where prior approval was not practicable.

Exceptional requests must not become a routine alternative to the normal access-request process.

Access Removal and Changes

When a user changes roles, leaves NexusTech or no longer requires access, the appropriate access-removal or modification process must be initiated. Access must be reviewed against current business requirements rather than being retained automatically.

Records and Audit Trail

Access requests, approvals, provisioning evidence, changes and closure information must be retained in the approved ticketing/workflow system according to NexusTech's applicable record-retention requirements. Records must show who requested access, who approved it, what was granted, why it was granted, who provisioned it, when it was provisioned and whether exceptions occurred.

Roles and Compliance

Role	Responsibility
Requester	Provides accurate access requirements and business justification.
Manager	Confirms the user's business need.
Data/System Owner	Approves access to resources under their responsibility.
Helpdesk/IT	Verifies the request and provisions approved access.
Information Security	Provides security oversight and reviews unusual, privileged or high-risk access where required.

Failure to follow this procedure may result in the request being rejected or escalated. Repeated non-compliance may be referred to management and Information Security.

EVIDENCE BUNDLE 4 - Communication and Training Plan

Audience	Key Message	Channel	Owner	Timing	Acknowledgment	Success Measure
All Employees	Use company systems/devices responsibly; unauthorised software, inappropriate activities and unauthorised data sharing are prohibited.	CEO announcement, all-hands, email, intranet	CEO + Information Security	18–21 Sept.	Electronic policy acknowledgment	≥95% acknowledgment; ≥85% knowledge-check score
IT / Helpdesk	Enforce approved access/security requirements; do not rely on informal access requests.	Role-specific workshop + mandatory module	Information Security Manager	21–23 Sept.	Training completion + acknowledgment	100% training completion
Managers	Reinforce AUP and support appropriate access and escalation.	Management briefing + email	Information Security + HR	22–24 Sept.	Manager attestation	≥95% completion

Audience	Key Message	Channel	Owner	Timing	Acknowledgment	Success Measure
HR	Support employee communication and escalation of relevant violations.	HR briefing	Information Security + HR	23 Sept.	Meeting record/acknowledgement	100% briefing completion
New Employees	AUP requirements form part of responsible use of NexusTech resources.	Onboarding module	HR + Information Security	From 25 Sept.	Electronic acknowledgement	100% completion within onboarding requirement

Rollout Timeline

Phase	Timing	Key Activities
1 — Announcement	18 Sept. 2026	CEO announcement; communicate purpose and effective date; publish policy internally.
2 — Awareness	21–24 Sept. 2026	All-hands session; manager and IT briefings; common unacceptable-use scenarios.
3 — Mandatory Training	21 Sept.–2 Oct. 2026	Mandatory module, knowledge check and policy review.
4 — Attestation	By 2 Oct. 2026	Electronic confirmation of receipt, understanding and compliance.
5 — Follow-up	5–9 Oct. 2026	Completion reports, reminders and escalation of unresolved non-compliance.

Effectiveness Measures

- Training completion rate — percentage of required employees completing the mandatory module.
- Policy acknowledgement rate — percentage of employees formally acknowledging the AUP.
- Knowledge-check performance — percentage achieving the required score.
- Follow-up compliance rate — percentage of initially non-compliant users completing requirements after reminders.

Non-Compliance and Escalation

Employees who fail to complete mandatory training or acknowledgement will first receive a reminder. Continued non-compliance will be escalated to the employee's manager. Where appropriate, HR will be involved in accordance with organisational disciplinary processes. Repeated misunderstanding identified through knowledge checks or observed behaviour will result in targeted refresher training. Serious or deliberate policy violations will be escalated to Information Security, management and HR as appropriate.

EVIDENCE BUNDLE 5 — Policy Review and Maintenance Memo

Memo Field	Value
To	Information Security Steering Committee
From	Information Security Manager
Date	18 September 2027
Subject	Review and Proposed Update of Acceptable Use Policy v1.0

Policy Review Memorandum

The Acceptable Use Policy should undergo an early review because two material changes have occurred since its implementation. First, NexusTech has migrated its primary database to AWS, creating a significant change in the organisation's technology environment and the way information is hosted, accessed and managed. This requires the AUP to be assessed against the organisation's current cloud-based operating environment. Second, an employee shared a sensitive document through a personal cloud-storage account. This incident demonstrates the need to review whether the existing policy provides sufficiently clear requirements concerning personal cloud services, sensitive information and approved methods of data sharing. These events therefore constitute appropriate review triggers in addition to the scheduled annual policy review.

The review should involve consultation with Information Security, IT, relevant system/data owners, HR, legal/compliance representatives and business stakeholders. The team should examine the incident record, relevant audit findings, current cloud-use practices, access controls, employee feedback and applicable organisational requirements. A risk assessment should determine whether existing AUP controls remain appropriate. At minimum, the revised AUP should explicitly prohibit the storage or sharing of sensitive NexusTech or client information through unauthorised personal cloud-storage accounts and clarify requirements for using approved corporate cloud services. It should also clarify acceptable use of cloud-based systems and employee responsibilities when accessing company information remotely. The Information Security Manager should remain the policy owner, with the revised policy submitted to the appropriate governance route and CEO approval authority before becoming effective.

Following approval, the revised AUP should be communicated to employees and incorporated into mandatory awareness training. A formal review should occur at least annually, with an earlier review triggered by significant technology or business changes, major security incidents, material regulatory changes, or significant changes to information-security risk.